OWASP Juice Shop — Security Assessment

A manual penetration test of a locally deployed OWASP Juice Shop instance, performed as a take-home security assessment.

Summary

8 findings identified across injection, broken access control, cross-site scripting, cryptographic failures, and authentication weaknesses — including one Critical issue allowing full admin takeover with no valid credentials.

#	Finding	Severity	CVSS 3.1
1	SQL Injection — Authentication Bypass	Critical	9.1
2	Broken Access Control — Admin Panel	High	8.0
3	DOM-based Cross-Site Scripting	Medium	6.1
4	Security Misconfiguration — Version Disclosure	Medium	5.3
5	Insecure Direct Object Reference — Basket	Medium	6.4
6	Weak Cryptographic Hash for Passwords	Medium	5.3
7	Insecure Password Recovery Mechanism	High	7.4
8	Missing Rate Limiting on Authentication	Medium	5.3

Scope

- Target: `bkimminich/juice-shop:latest`, deployed via Docker (`docker run -d -p 3000:3000 bkimminich/juice-shop`)
- Environment: Local only (`http://localhost:3000`), no production or external systems in scope
- Approach: Manual grey-box testing, following the OWASP Testing Guide and OWASP Top 10 (2021)
- Tools: Chrome DevTools (Network/Console), manual payload crafting

Contents

- `REPORT.md` — full report: executive summary, methodology, findings table, and all 8 detailed findings with CVSS vectors, reproduction steps, business impact, and

remediation

- `screenshots/` — supporting evidence for each finding (add your captured screenshots here, named `findingN_*.png`)

Disclaimer

This assessment was performed exclusively against a local, isolated, intentionally vulnerable training application for educational purposes. No production systems were tested.